

מפגש 3 - סוגי איומים – והמשך INFOSEC

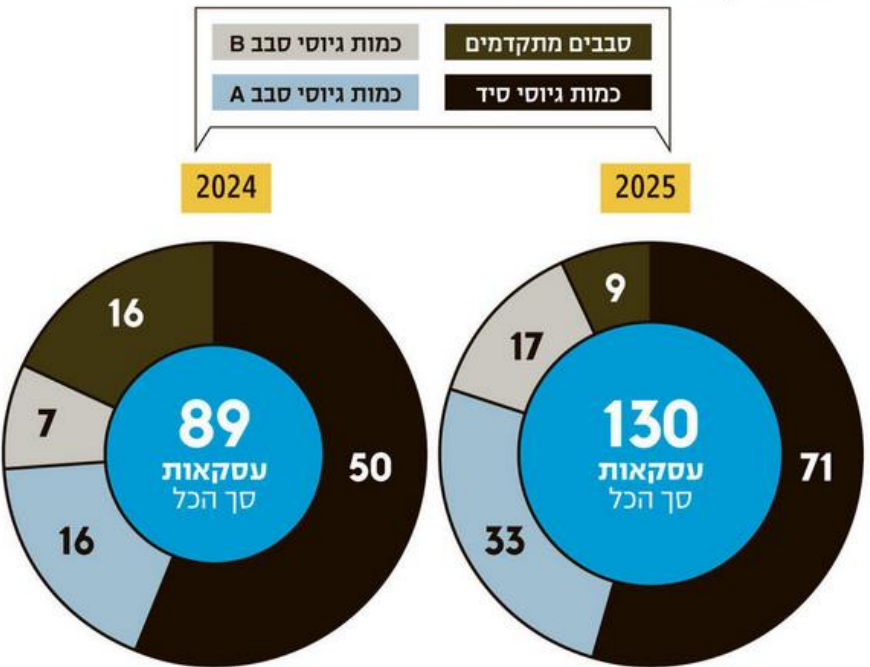
המיזמים הישראליים בעולמות של CYBER

יותר כסף, יותר עסקאות, בסכומים גדולים יותר לגיוס בסייבר

סך כל גיוסי ההון בסטארטאפים ישראלים בתחום הסייבר במיליארדי דולרים
המימון לחברות סייבר הנשענות על בינה מלאכותית צפוי כמעט להכפיל את עצמו

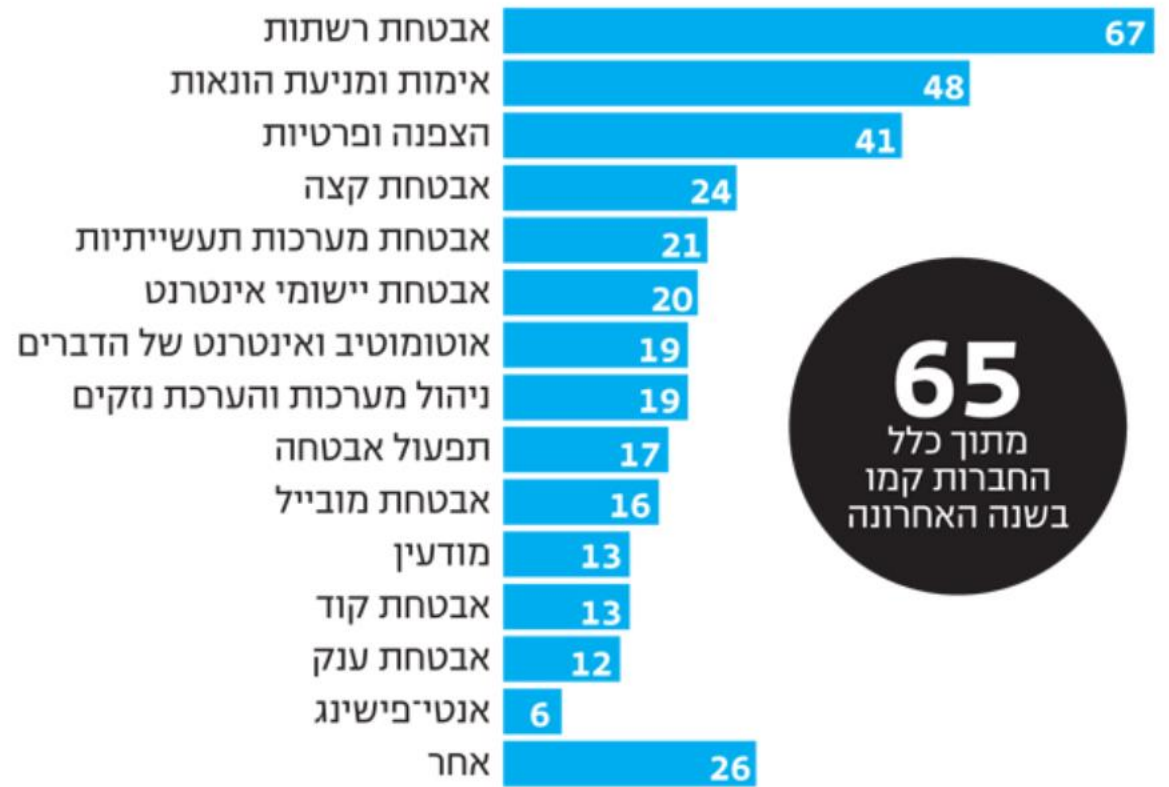


כמות העסקאות כמות כלל הגיוסים



הסייבר הישראלי מתפוצץ

תחומי חברות סייבר בישראל מספר חברות



65 מתוך כלל החברות קמו בשנה האחרונה



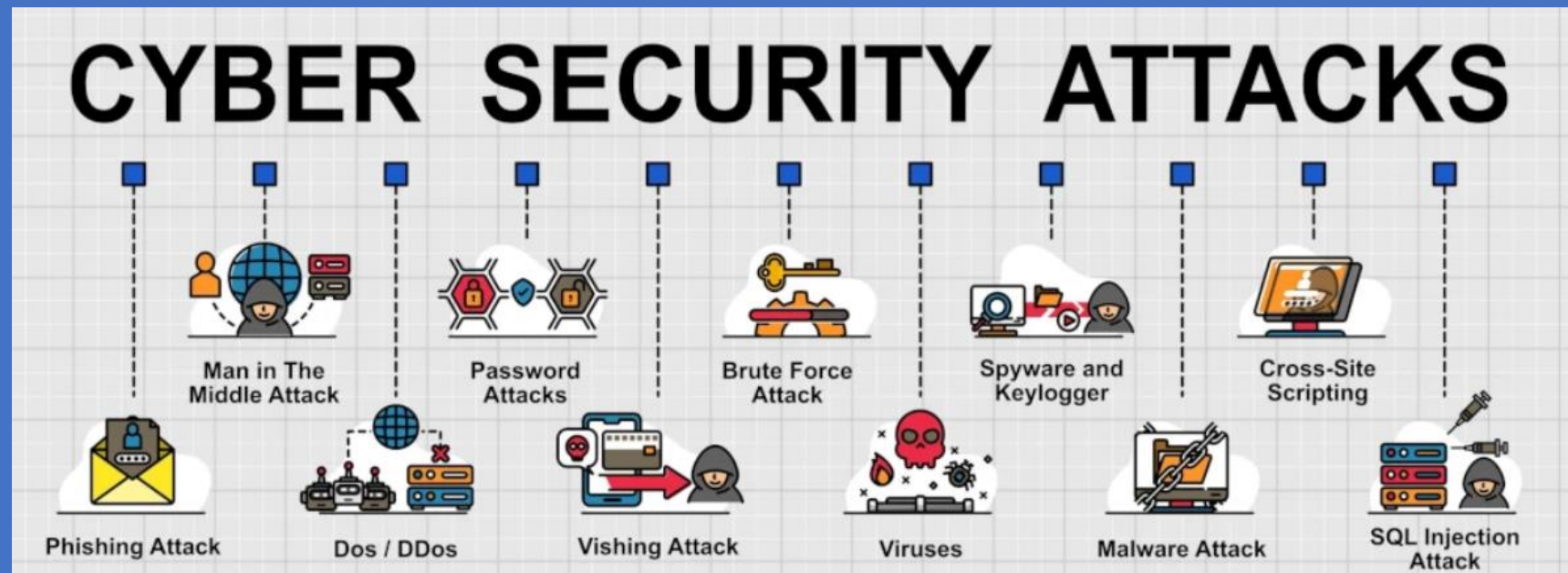
סקירת איומי הסייבר העכשוויים

הגברת מורכבות האיומים

העלייה במורכבות האיומי הסייבר, הכוללים מתקפות מתוחכמות ומתקדמות, מחייבת גישה מתוחכמת להגנה.

גידול בהיקף ההתקפות

התגברות בהיקף ההתקפות הסייבר ברחבי העולם, עם מטרות שונות, כגון גניבת מידע, שיבוש פעילות, וחבלה.



Threat Escalation

238%

זינוק במתקפות סייבר
מבוססות AI במהלך 2023.

- יצר נזק גלובלי מצטבר של מעל 8.5 מיליארד דולר.



(IJFMR Analysis)

Financial Impact

\$10.22M

שיא של כל הזמנים – העלות
הממוצעת לדלף מידע בארה"ב.

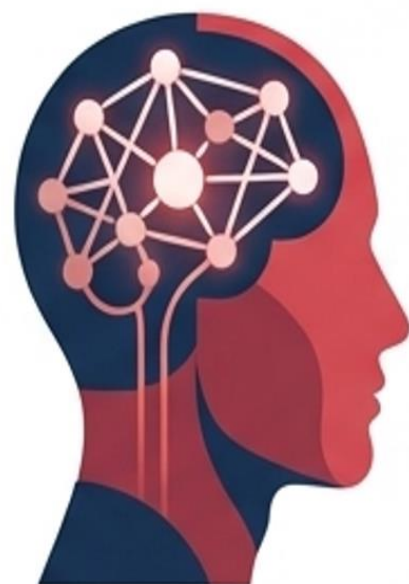
- 65% מהארגונים מדווחים כי מעולם לא התאוששו לחלוטין מאירוע הפריצה.
- זמן התאוששות ממוצע עומד על למעלה מ-100 ימים.

(MJ Companies / IBM Report)



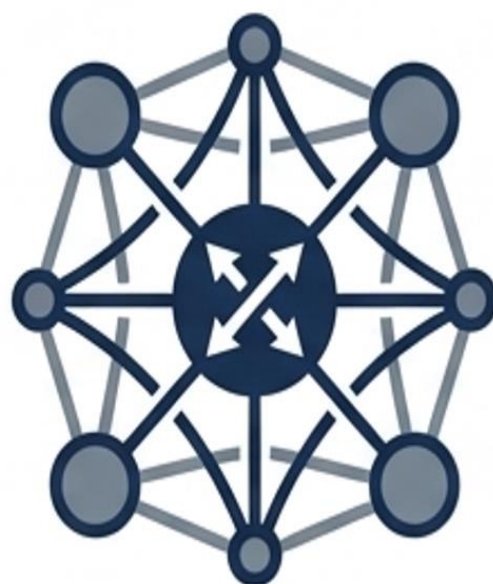
נקודת התפנית: פתרונות אבטחה מסורתיים קורסים מתמטית וכלכלית
תחת המהירות והתחכום של האיומים החדשים.

3 חזיתות האיום המרכזיות שמעצבות מחדש את משטח התקיפה



הגורם האנושי (AI & Deepfakes)

הנדסה חברתית היפר-מותאמת
אישית, שכפול קול (Voice Cloning),
וקמפיינים רב-ערוציים שעוקפים
את חומת האש האנושית.



נתיב התקשורת (Modern MITM)

חטיפת עוגיות התחברות
(Session Cookies), מעקף אימות
רב-שלבי (MFA), וניצול חולשות
במכשירי IoT וסלולר.



הליבה הקריפטוגרפית (Quantum Computing)

קריסת ההצפנה האסימטרית
ואסטרטגיית 'אסוף עכשיו, פענח
פענח מאוחר יותר' (HNDL)
שמסכנת נתונים היסטוריים.

חזית 1: בינה מלאכותית ותחילת ההנדסה החברתית



- 50% ממיילי הפישינג כיום מדמים תהליכי עבודה ארגוניים לגיטימיים (Spear-phishing). שיטות ה-Spray-and-pray נעלמו.

Case File



הנשק בעל הצמיחה המהירה ביותר

מתקפות קוליות מבוססות AI חוות פי 2 שיעור אינטראקציה ממתקפות רגילות.

אירוע עוקץ של 1 מיליון יורו. תוקפים השתמשו בטכנולוגיית **Deepfake** קולית כדי להתחזות לשר ההגנה האיטלקי, ושכנעו את משפחות ברטה ובוגאטי להעביר כספים תחת מעטה של 'דחיפות ביטחונית'.

היתרון הלא-הוגן של מכונת התקיפה

	תוקף מסורתי	תוקף מבוסס AI
פיצוח סיסמאות (12+ תווים)	 7% אחוזי הצלחה (10,000 ניסיונות/שנייה)	 41% אחוזי הצלחה (2.7 מיליון ניסיונות/שנייה, רשתות עצביות) קיצור זמן של 92%
גילוי חולשות (סריקה)	 12 שעות סריקה (35% התראות שווא)	 2.5 שעות סריקה (12% התראות שווא, זיהוי אוטונומי) ייעול של 93.75%
עלות תפעולית לתוקף (ROI)	 \$1,200 למתקפה	 \$335 בלבד למתקפה החזר השקעה (ROI) של 285% לתוקף

חזית 2: מתקפות Man-in-the-Middle בעידן המודרני

האשליה ש-MITM זו בעיה של 'מחשב נייד בבית קפה' מתנפצת אל מול משטחי תקיפה חדשים.



Shadow IT & Messaging

מעבר לאפליקציות כגון Signal ו-WhatsApp המספקות גישה ישירה ופרטית ועוקפות את מערכות הניטור הארגוניות.



Mobile & Apps (MITMO/MITA)

יירוט אימותים סלולריים מבוססי SMS (mTANs).
אפליקציות רבות נכשלות באימות תעודות SSL, מה שמאפשר הזרקת תעודות מזויפות.



Cloud (MITC)

גניבת אסימוני פעולה (Tokens Session) המאפשרת שליטה מלאה בחשבון הענן ללא צורך לדעת את הסיסמה עצמה.



IoT & Bluetooth

כ-80% מהתקני ה-BLE הארגוניים פגיעים לחטיפת MITM עקב קונפיגורציה לקויה.

חזית 3: האיום הקוונטי וקריסת ההצפנה הציבורית

הבעיה המהותית

מחשבים קוונטיים בעלי רלוונטיות קריפטוגרפית (CRQC) לא סתם 'פורצים' מהר יותר – הם משכתבים משכתבים את המתמטיקה של ההצפנה.

אלגוריתם שור (Shor's Algorithm)

הופך את רוב תשתיות ההצפנה הציבוריות הקיימות (RSA, ECC, -) EJC, Diffie-Hellman) למוצות לחלוטין.

אלגוריתם שור (Shor's Algorithm)

הופך את רוב תשתיות ההצפנה הציבוריות הקיימות (RSA) ECC, Diffie-Hellman) למיושנות ופרוצות לחלוטין.

חלון הזמן

למרות ש-Q-Day עשוי להיות במרחק של עשור, הזמן הנדרש לארגון להגר לתקני הצפנה חדשים עומד על שנים. ההמתנה היא הסכנה המיידית.



נקודת הסינתזה: הא-סימטרית המוחלטת של הלוחמה בסייבר

צונחים דרמטית.
תודות לאוטומציית AI,
כלי OSINT חינוניים,
ומערכות תקיפה זמינות
זמינות בענן שמורידות
את עלות התקיפה ל
\$3357 בלבד.



מזנקים לשיא.
נזק ממוצע של \$10.2M
10.2M\$ לפריצה, עם
זמני התאוששות
שחוצים את רף ה-100
ימים.

שינוי הפרדיגמה בהגנה: מלחמה ב-AI בעזרת AI

	חכם AI-SOC	טכנולוגיית Legacy
 זיהוי איומי Zero-day	67% 67% +44% (קפיצה של +44%)	23% בלבד
 זמן תגובה לאירוע (Incident Response)	8 דקות בלבד -97.8% (קיצור דרמטי של 97.8% באמצעות אורקסטרציה אוטומטית)	6 שעות בממוצע מחשיפה לתגובה
 אנליטיקה התנהגותית (UEBA)	73% הפחתה של בהתראות שווא 99.7% אחוזי הצלחה בתגובה לאנומליות	ריבוי התראות שווא 'ועייפות התראות'

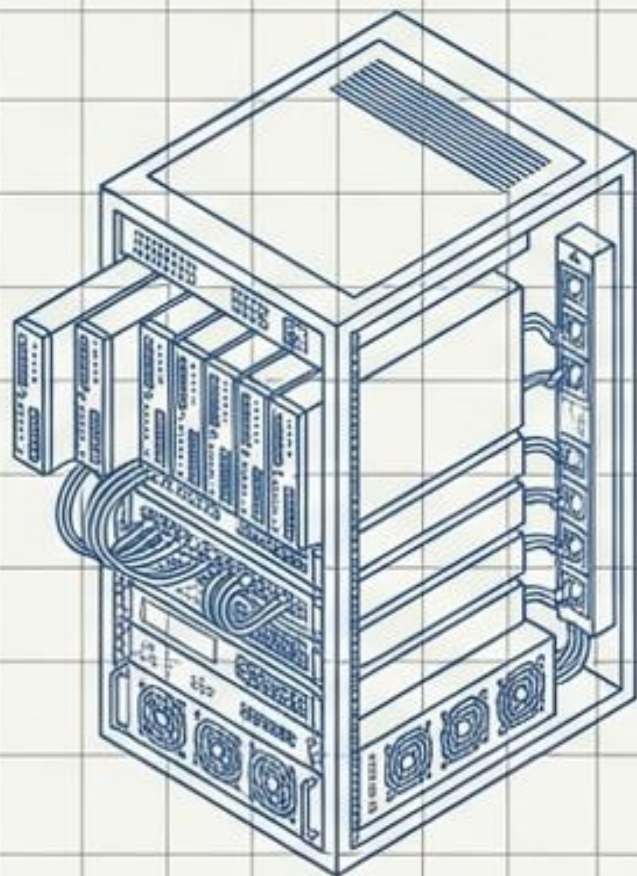
Ferrari Hit the Brakes on a Deepfake CEO

יולי 2024

- מפעל הייצור של פרארי קיבל מספר הודעות כתובות וקוליות בוואטסאפ ממה שנראה כמו המנכ"ל של החברה - Benedetto Vigna
- הודעות היו במבטא איטלקי של המנכ"ל, והסבירו שכלל הצצדים כבר עודכנו, כולל מערכת רגולטורית, לטובת רכישה של חברה מתחרה גדולה, והעברת סכום כסף משמעותי
- על מנת לוודא את הזהות, המנהלים הבכירים בארגון שאלו את המתקשר איזה ספר הכי אהוב עליו, פה נחסם ניסיון ההונעה.



שתי חזיתות הלחימה של הסייבר



הבאג במערכת (ניצול טכנולוגי): עקיפת המשתמש לחלוטין באמצעות ניצול פרצות קוד, חולשות גם ימים (Zero-Day), והעמסת משאבי הרשת.

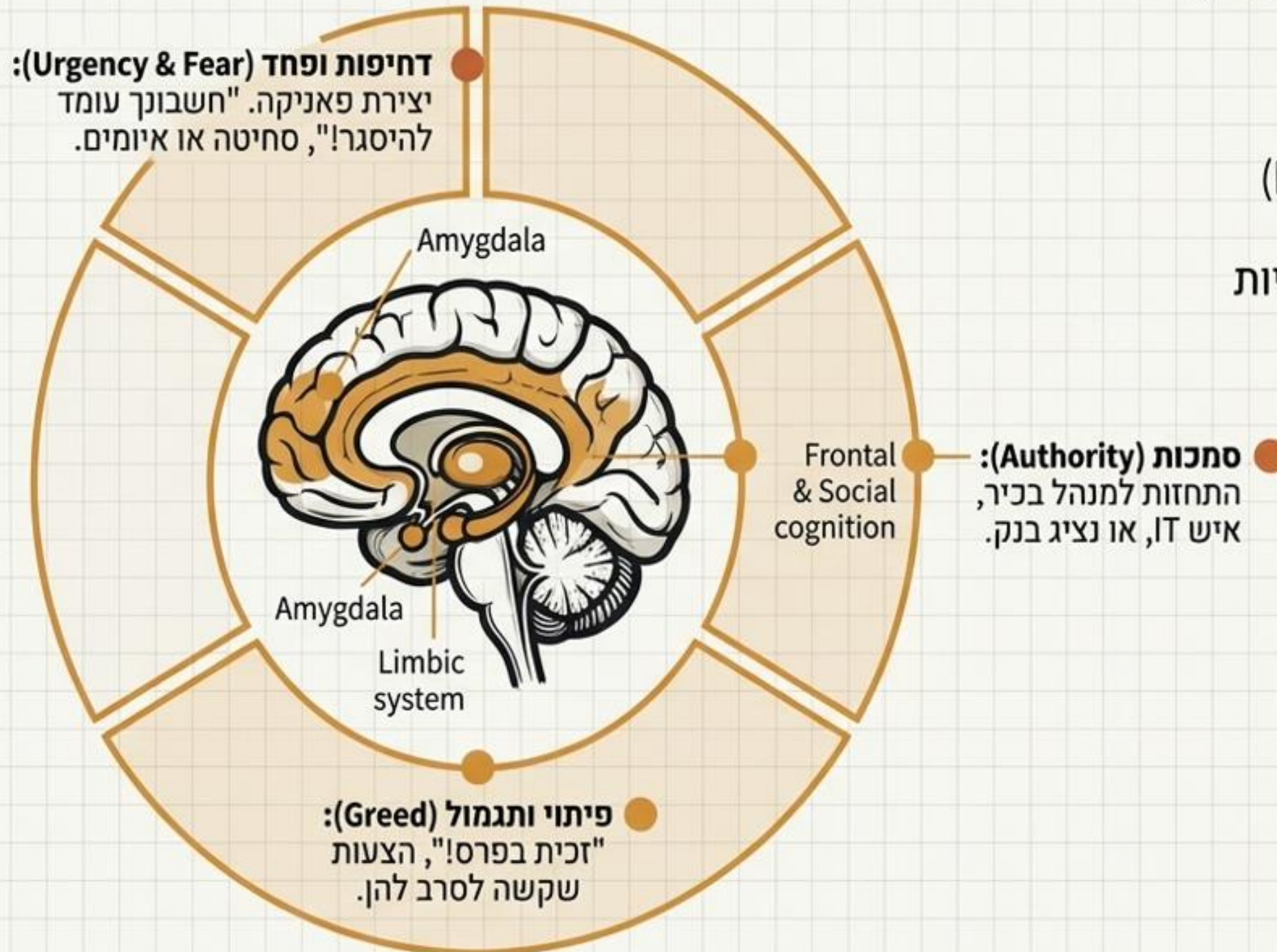


הבאג האנושי (הנדסה חברתית): ניצול פסיכולוגיה אנושית, יצירת אמון, ושימוש במניפולציות כדי לגרום למשתמש למסור למסור מידע מרצונו.

פריצה למוח האנושי: הנדסה חברתית

אין צורך לעקוף את חומת האש (Firewall) אם אפשר פשוט לבקש את הסיסמה. הנדסה חברתית מנצלת תכונות פסיכולוגיות כדי להשיג ציות.

לולאת ההונאה



ספקטרום הדיוג (Phishing Spectrum):

סוג התקיפה	ערוץ פעולה	קהל יעד	מטרת התקיפה
פישנינג (Phishing)	דוא"ל המוני	תפוצה רחבה (General)	איסוף סיסמאות ופרטי אשראי
ספיר פישנינג (Spear Phishing)	דוא"ל ממוקד	עובד ספציפי בארגון	חדירה לרשת הארגונית
וישינג (Vishing)	שיחת טלפון קולית	לקוחות / עובדים	השגת קודי אימות ופרטי זיהוי בזמן אמת
סמישינג (Smishing)	מסרונים (SMS)	משתמשי סלולר	התקנת נוזקה בנייד או גניבת זהות

תקיפות ממוקדות מטרה



תרמית הלווייתן (Whaling).

ציד ה"דגים השמנים".
התחזות למנכ"ל או סמנכ"ל כספים.
הפנייה היא לרוב לעובדי הנהלת חשבונות
בהוראה דחופה לבצע **העברת כספים מיידית**
או **לחשוף סודות מסחריים**.



ספיר פישינג.

מתקפה מותאמת אישית.
התוקף אוסף מידע מוקדם על העובד
וסביבת עבודתו כדי לשלוח הודעה אמינה ביותר
(למשל, קובץ "דוח כספי" נגוע מ"קולגה").
המטרה: השגת דריסת רגל ראשונית ברשת.

המלכודת המודרנית: Angler Phishing

אנומליה: שגיאת כתיב בשם המשתמש



אנומליה: קישור חשוד ובלתי מאומת



עברייני רשת כבר לא מחכים בתיבת הדוא"ל. הם אורבים ברשתות החברתיות (X, פייסבוק, אינסטגרם) ומנצלים תלונות פומביות של לקוחות מתוסכלים.

התוקף מקים פרופיל מזויף הנראה זהה לחלוטין לשירות הלקוחות הרשמי (עם שגיאת כתיב קלה בשם המשתמש). הוא מגיב במהירות לתלונת הלקוח ומציע "עזרה מיידית", תוך ניצול האמון שהלקוח רוחש למותג.

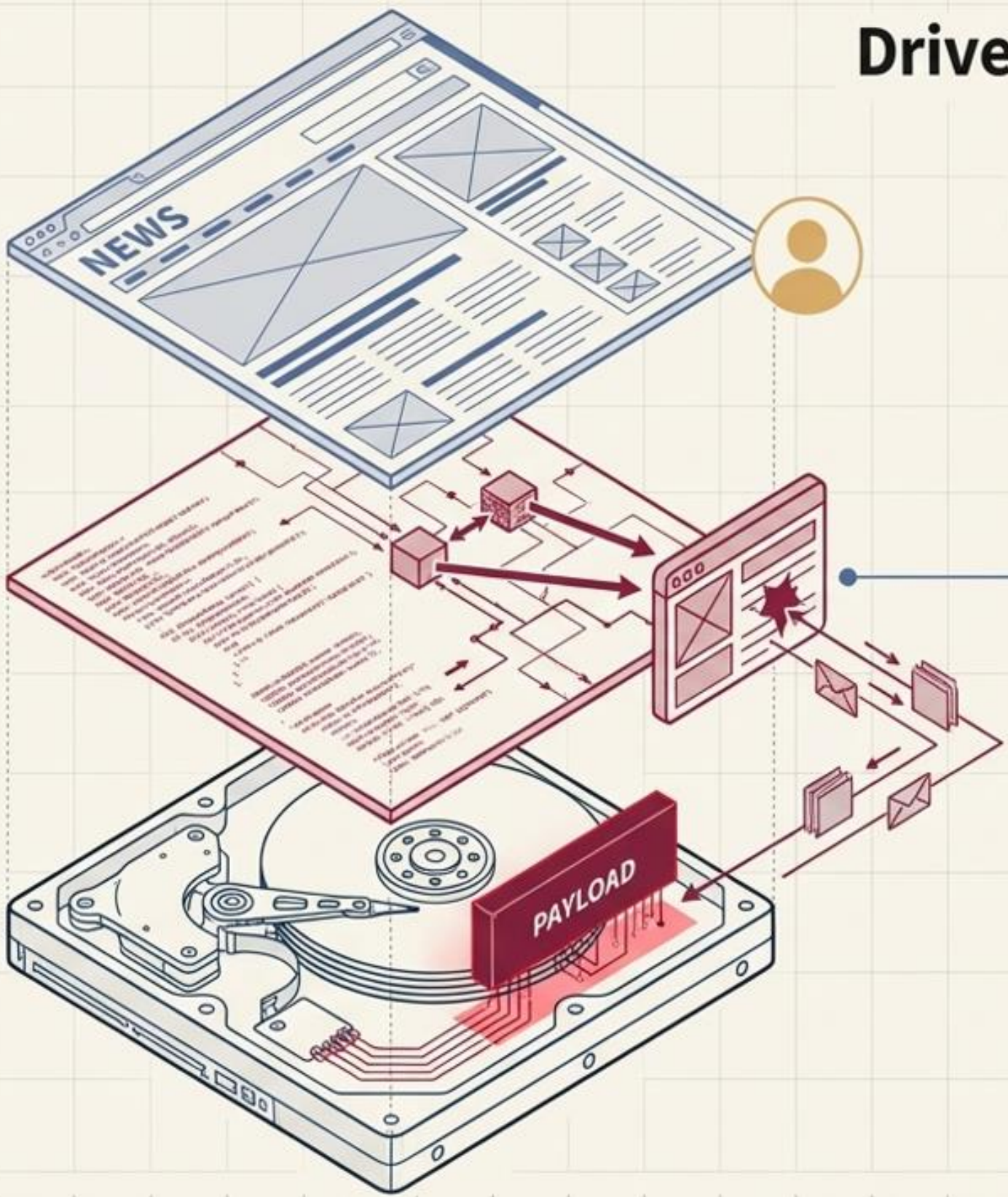
האיום השקוף: Drive-by Download

הדבקה ללא צורך בלחיצה. גלישה תמימה לאתר לגיטימי שהותקף (או דרך פרסומת נגועה) מספיקה כדי להחדיר נזקה למכשיר.

Top Layer
(The Interface)

Middle Layer
(The Exploit)

Bottom Layer
(The Payload)



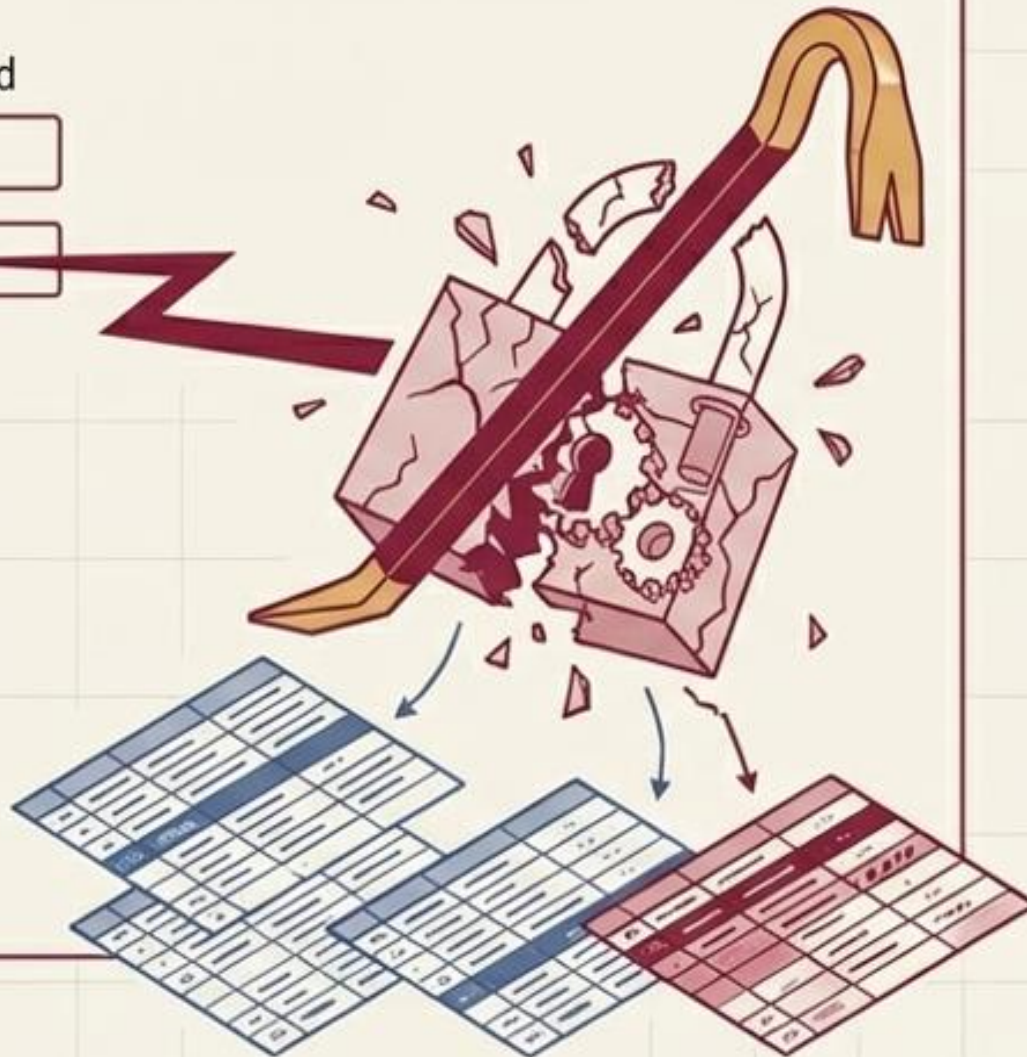
הקוד הזדוני רץ ברקע, סורק את הדפדפן, מערכת ההפעלה או התוספים (Plug-ins) של המשתמש בחיפוש אחר חולשות אבטחה שלא עודכנו. ברגע שנמצאת פרצה, מטען ייעודי (Payload) יורד ומופעל באופן אוטומטי לחלוטין.

הזרקת SQL: שבירת מסד הנתונים

אתרים דינמיים מסתמכים על שפת SQL כדי לתקשר עם מסדי הנתונים (DB) שלהם.

הזרקת קוד

Username / Password



קלט תקין

Username / Password

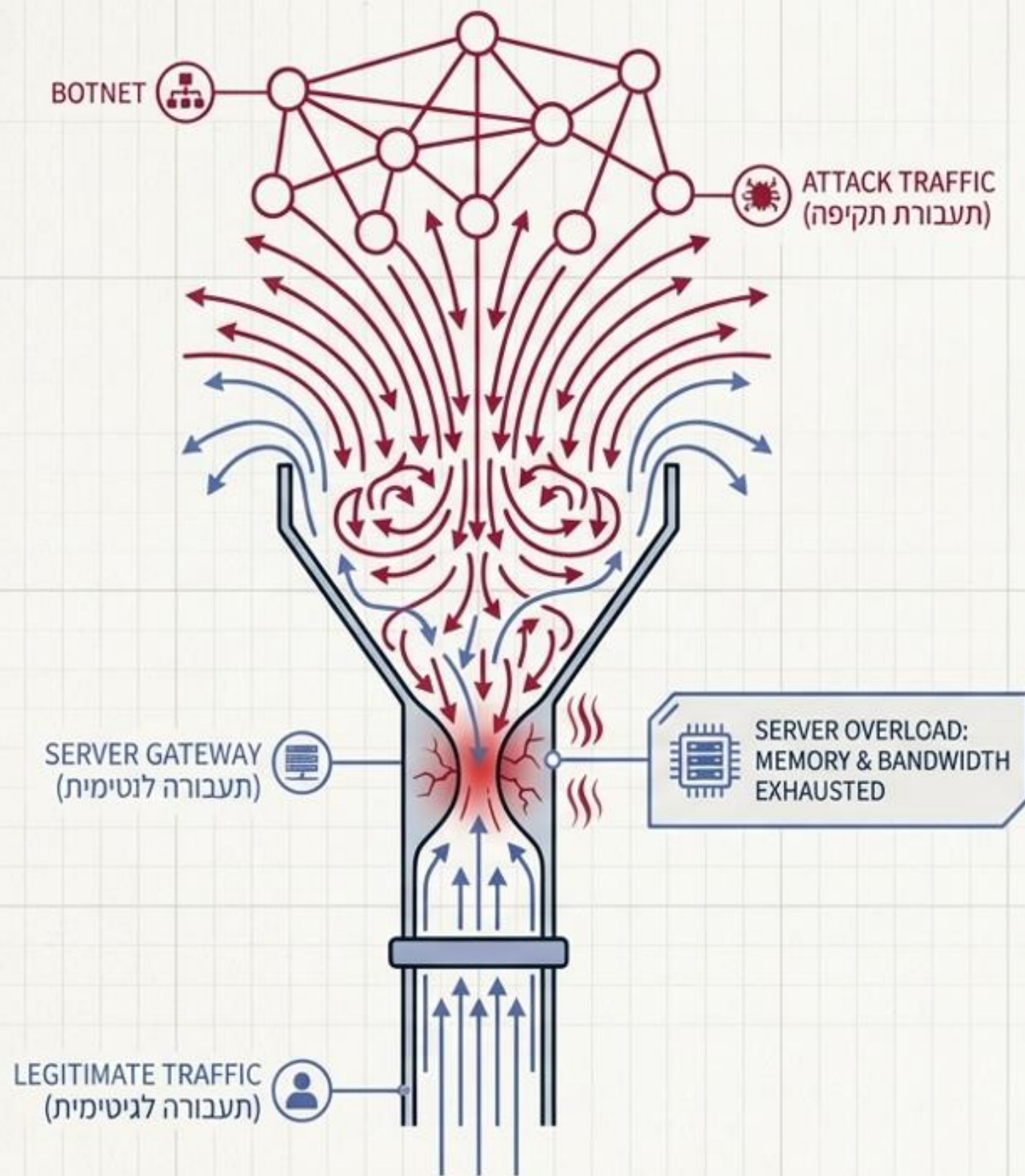


כאשר שדות קלט אינם מסוננים כראוי, תוקף יכול להול להקליד פקודות SQL ישירות לתוכם. הפקודות הללו משבשות את הלוגיקה של המערכת, עוקפות אימות, וחושפות או מוחקות את המידע הרגיש ביותר בארגון.

מתקפת מניעת שירות (DDoS): חנק משאבים

המטרה כאן אינה גניבת מידע, אלא השבתה מוחלטת של השירות (Denial of Service).

התוקף רותם צבא של מחשבים נגועים (Botnet) כדי לשלוח כמות אדירה של בקשות סנכרון אל שרת המטרה בו-זמנית. השרת קורס תחת העומס, זיכרון ורוחב הפס אוזלים, ומשתמשים לגיטימיים נחסמים לחלוטין.





מיהו ה KPI - Key Performance Indicator

- שם למדדים שחברות וארגונים בוחרים על מנת למדוד את הביצועים וההישגים שלהם.
- מדד KPI פופולרי בחברות הוא כמות ההכנסות מידי חודש.
- ניתן לבחור גם מדדים לא כלכליים כמו "כמה משתמשים סיימו את ההרשמה באפליקציה".
- כל דבר שניתן למדוד וחשוב לחברה למדוד, יכול להיבחר כ-KPI.

האתגר המשפטי: עמידה בדרישות רגולציה

חוקי הגנה על מידע

הבנה של חוקי הגנה על מידע וחובות הארגון במסגרת חוקים אלה.

התאמה לדרישות

הבטחת התאמה של מערכות ההגנה לדרישות הרגולציה המתפתחות
(CobIT ,ITIL ,NIST ,CSA ,PCI-DSS ,SOX ,ISO/IEC 27000)

ניהול סיכונים משפטיים

זיהוי ושליטה בסיכונים משפטיים הקשורים להגנה על מידע.

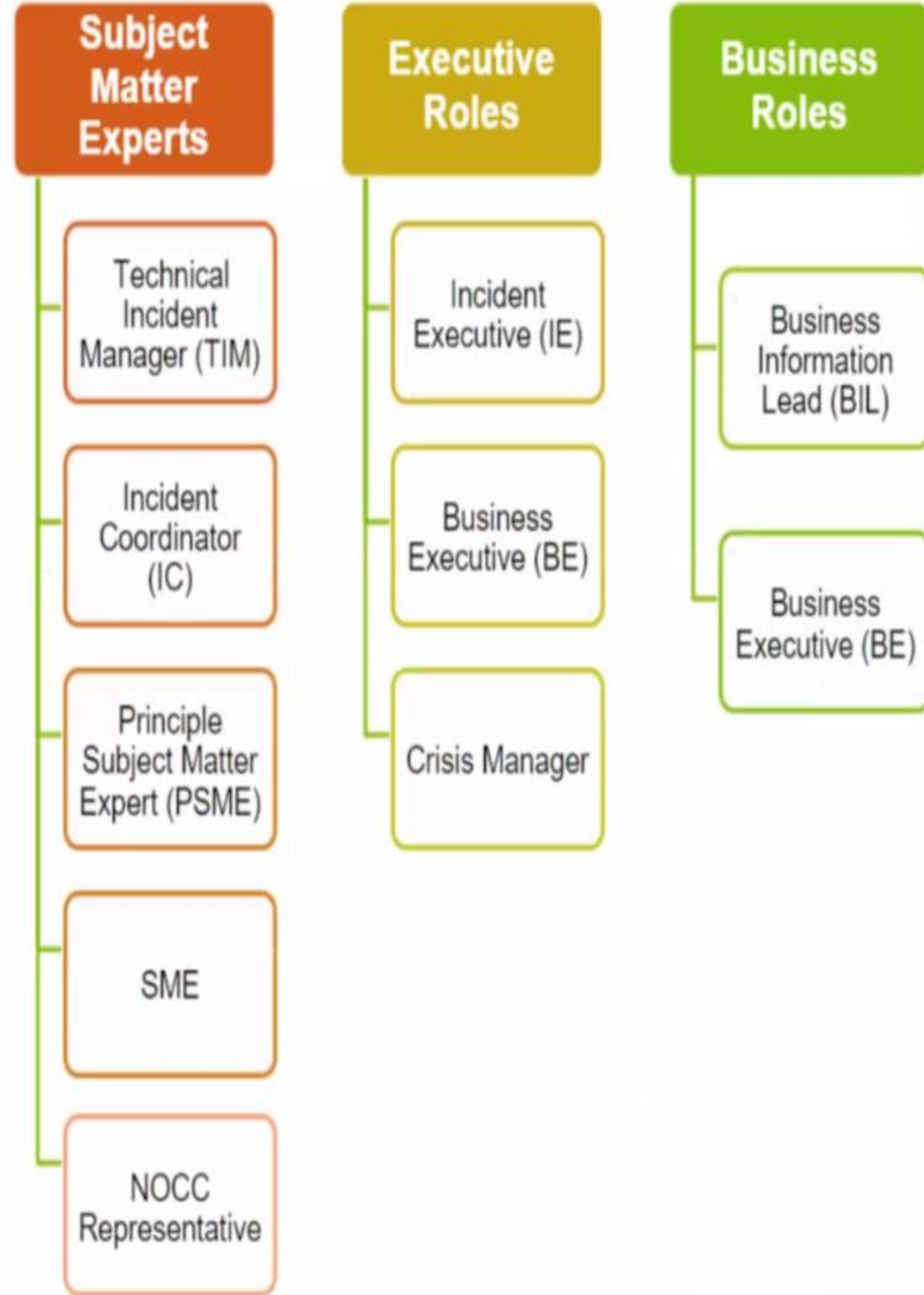


1

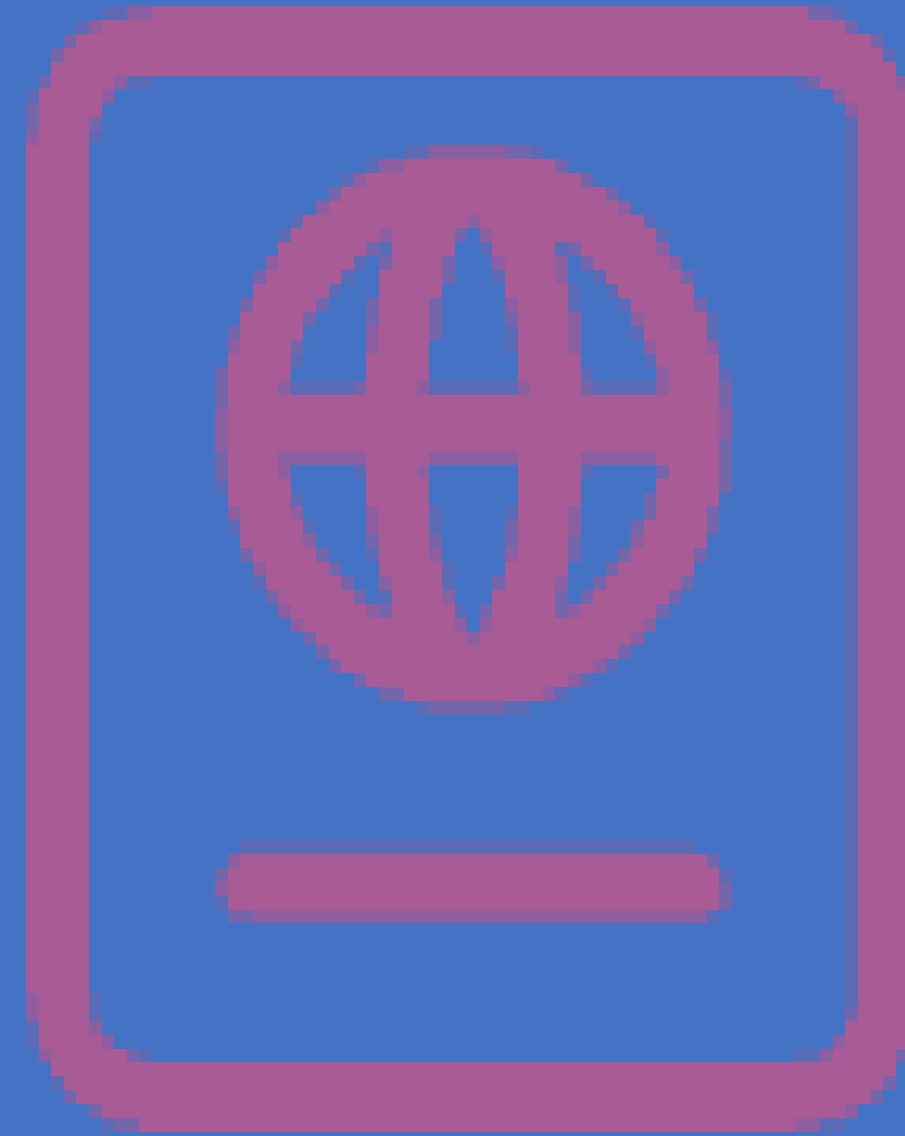
2



People on an Incident



מי מטפל באירוע ?



NOCC – Network Operations Control Center

Decision Authority by Severity

Role	Severity 4	Severity 3	Severity 2	Severity 1
SMEs	👤	👤	👤	👤
TIM, or (PSME and IC) (Incident Lead)	👤	👤	👤	👤
Business Information Lead	👤	👤	👤	👤
Incident Executive			👤	👤
Business Executive			👤	👤
Criss Manager				👤



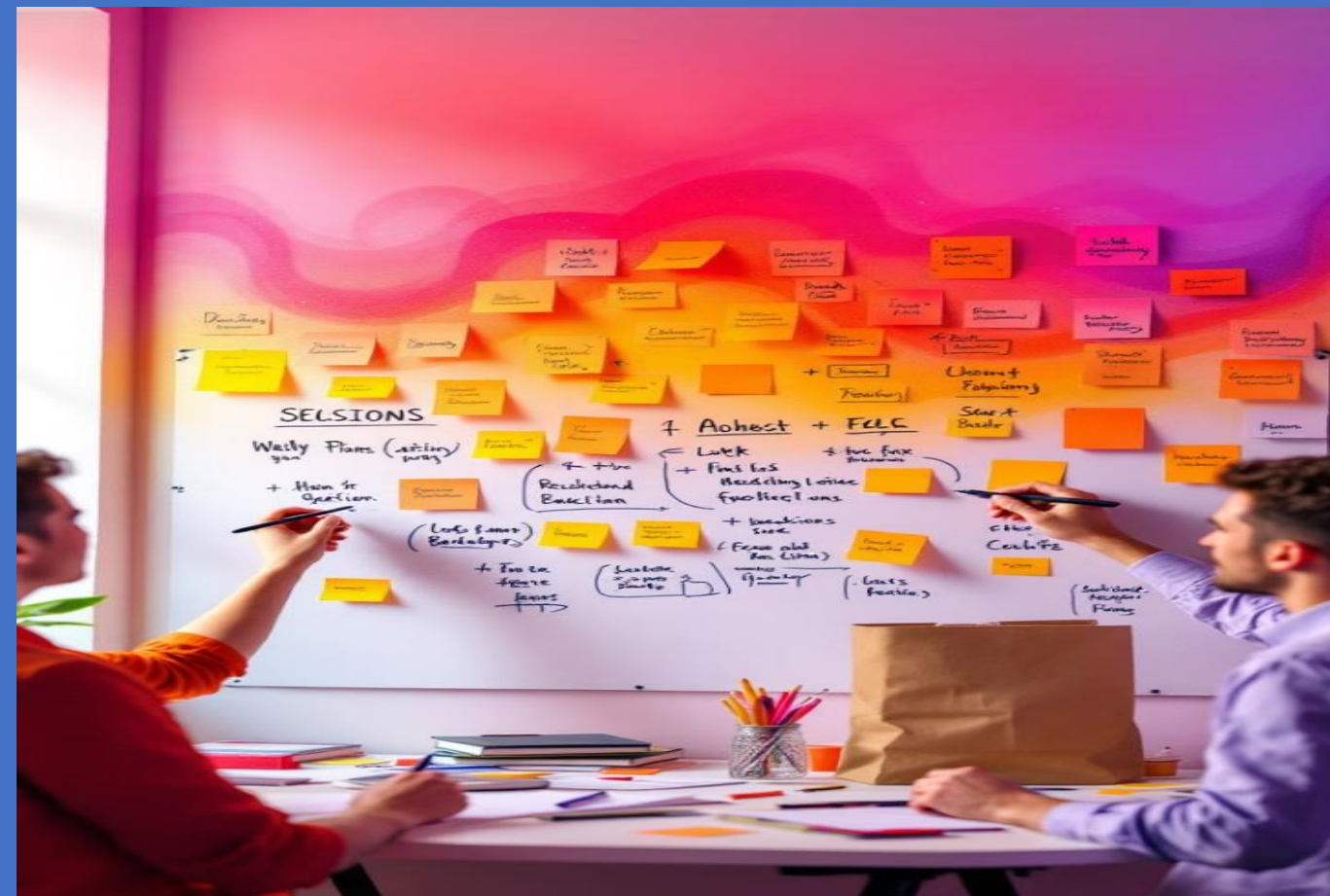
Role with decision authority at the indicated severity level.



Role is required at the indicated severity level.

בעלי תפקידים המעורבים באירוע

לא בכול אירוע מעורבים כלל בעלי התפקידים



תגובה לאירועי אבטחה והפקת לקחים

זיהוי תקלה

1

הערכת נזק

2

תגובה מהירה

3

חקירה וניתוח

4

הפקת לקחים

5

אחת ההתקפות הקשות ב 2023 - MOVEit

- מתקפת Lace Tempest (Storm0950)
- שימוש בחולשת zero-day בתוכנה פופולרית כדי לקבל גישה לסביבת הלקוח
- עדיין לא ברור לחלוטין כמה נתונים נלקחו וכמה קורבנות ישנם
- מדובר ביותר מ-2,600 ארגונים ומעל 83 מיליון משתמשים שונים
- זה שרבים מהארגונים האלה היו ספקי מוצרים או שירותים בעצמם רק הוסיף למידת ההשפעה של המתקפה..



STARTUP IDEAS

האם הרעיון שלכם טוב או לא ?

- חושבים שיש לכם רעיון מקורי ומגניב שישקיעו בו ?

- רוצים לדעת האם קרן השקעות תשקיע בו ?

- <https://www.inno-path.io/>

Q & A

